

UniQueue System Testing Document

This document outlines the testing phase of the UniQueue system, verifying core functionalities including authentication, role-based access control, resource reservation, and notification systems.

1. Testing Methods

- **Manual Testing:** Extensive manual testing was performed via UI and API clients (such as Postman) to ensure endpoint stability, correct status codes, and accurate data retrieval.
- **Integration Testing:** Tested the seamless data flow between the Node.js/Express backend and the Microsoft SQL Server database. Verified that queries and mutations successfully persist and retrieve data.
- **Security & Authorization Testing:** Evaluated the JWT (JSON Web Token) implementation and the Role-Based Access Control (RBAC) middleware to ensure users could not access or mutate data outside their permitted scope.
- **Boundary & Validation Testing:** Tested the time slot logic for office hours to ensure overlapping boundaries were correctly rejected and duration intervals (15-60 mins) were strictly enforced.

2. Test Cases

A. Authentication & Authorization

Test Case ID	Description	Expected Outcome
AUTH-01	User logs in with correct email and password	Success (200 OK), JWT token generated.
AUTH-02	User logs in with unregistered email	Error (401 Unauthorized), generic error message.
AUTH-03	User logs in with correct email but wrong password	Error (401 Unauthorized), generic error message.
AUTH-04	Student attempts to access Admin endpoints	Error (403 Forbidden).

B. Role-Based Access Control (RBAC)

Test Case ID	Description	Expected Outcome
RBAC-01	Lecturer adds office hours for themselves	Success (201 Created).
RBAC-02	Lecturer attempts to edit another lecturer's office hours	Error (403 Forbidden).
RBAC-03	Bus Driver adds a transit line under their ownership	Success (201 Created).

Test Case ID	Description	Expected Outcome
RBAC-04	Bus Driver attempts to update a transit line	Error (403 Forbidden / Not Allowed).
RBAC-05	Admin performs CRUD operations on any resource	Success.

C. Resource Reservation (Office Hours & Study Rooms)

Test Case ID	Description	Expected Outcome
RES-01	Student books an available 30-min office hour slot	Success, reservation status set to 'pending' or 'approved'.
RES-02	Student books a slot that overlaps with an existing booking	Error (409 Conflict / 400 Bad Request).
RES-03	Student requests a slot outside the session window	Error (400 Bad Request).
RES-04	Student requests a duration that is not a multiple of 15	Error (400 Bad Request).

D. Notifications

Test Case ID	Description	Expected Outcome
NOT-01	Lecturer updates/cancels their office hours	Associated students receive a notification.
NOT-02	Bus Driver removes a transit line	All students receive a system-wide notification.
NOT-03	Student waitlist promotion	System notifies the student that their booking is active.

3. Errors/Bugs

During the testing phase, the following issues were encountered and resolved:

- **Bug 1: Time Slot Overlap Allowed**
 - *Issue:* Initially, two students could book intersecting office hours if the start times were different (e.g., 14:00-14:30 and 14:15-14:45).
 - *Fix:* Improved the SQL query logic in `reservationController.js` to correctly check if $(newStart < existingEnd \text{ AND } newEnd > existingStart)$.
- **Bug 2: Information Disclosure on Login**
 - *Issue:* The login endpoint returned specific messages like "User not found" or "Wrong password", which could lead to email enumeration attacks.

- *Fix:* Standardized the error message to return "Invalid email or password" for any authentication failure in `authController.js`.
- **Bug 3: Unauthorized Resource Modification**
 - *Issue:* Lecturers could modify office hours belonging to other lecturers by manipulating the `resourceID` in the payload.
 - *Fix:* Added an ownership verification check in the update controller to ensure `resource.ownerID === req.user.userId` before processing the update.

4. Test Results

- **Authentication & Security:** PASS. JWT tokens are correctly signed and validated. RBAC effectively prevents unauthorized endpoint access.
- **Data Integrity:** PASS. SQL Server correctly persists data, and relationships (Foreign Keys) maintain referential integrity.
- **Business Logic (Reservations):** PASS. Overlapping bookings are reliably blocked, and validations on time boundaries work as expected.
- **Notifications:** PASS. Trigger events successfully insert notification records for the intended users.
- **Overall Status:** STABLE. All critical paths and user workflows are functioning according to the system specifications.